Enterprise AI Trust, Risk & Governance Management Platform

Project Phase-I Report submitted to Osmania University, Hyderabad, in partial fulfillment of the requirement for the award of the degree of

Bachelor of Engineering

in

Information Technology

By

Mr. Mohammed Sohail Ahmed	**(160923737008)**
Mr. Syed Sameer	**(160923737046)**
Mr. Shaik Waseem	**(160923737056)**

Under the Guidance of
Dr. Ayesha Mariyam
Associate Professor

DEPARTMENT OF INFORMATION TECHNOLOGY
LORDS INSTITUTE OF ENGINEERING AND TECHNOLOGY
(UGC Autonomous)
(Affiliated to Osmania University)
Himayathsagar, Hyderabad,500091

A.Y. 2026-2027



LORDS INSTITUTE OF ENGINEERING AND TECHNOLOGY
(UGC Autonomous)
(Affiliated to Osmania University)
Himayathsagar, Hyderabad, 500091
Department of Information Technology

CERTIFICATE

This is to certify that the Project Phase-I report entitled **Enterprise AI Trust, Risk & Governance Management Platform** being submitted by **Mr. Mohammed Sohail Ahmed (160923737008), Mr. Syed Sameer (160923737046), Mr. Shaik Waseem (160923737056)** in partial fulfillment of the requirements for the award of the degree of **Bachelor of Engineering** in **Information Technology** is a record of Bonafide work carried out by them.

Internal Project Guide
Dr. Ayesha Mariyam
Associate Professor

Dr. K. Nagi Reddy
H.O.D, I.T

External Examiner



LORDS INSTITUTE OF ENGINEERING AND TECHNOLOGY
(UGC Autonomous)
(Affiliated to Osmania University)
Himayathsagar, Hyderabad, 500091
Department of Information Technology

DECLARATION BY THE CANDIDATES

We, **Mr. Mohammed Sohail Ahmed (160923737008), Mr. Syed Sameer (160923737046), Mr. Shaik Waseem (160923737056)** hereby declares that the Project Phase-I report entitled **Enterprise AI Trust, Risk & Governance Management Platform** is carried out under the guidance of **Dr. Ayesha Mariyam**, Associate Professor, Department of Information Technology, **Lords Institute of Engineering and Technology**, **Hyderabad** is submitted in partial fulfillment of the requirements for the award of the degree of **Bachelor of Engineering** in **Information Technology.**

This is a record of Bonafide work carried out by us and the results embodied in this project have not been reproduced or copied from any source. The results embodied in this project report have not been submitted to any other university or institute for the award of any other degree or diploma.

Mohammed Sohail Ahmed (160923737008)
Syed Sameer (160923737046)
Shaik Waseem (160923737056)

ACKNOWLEDGMENT

We are very pleased to present this thesis of our project. This period of our student life has been truly rewarding a number of people were of immense help to us during the course of our research and the preparation of our thesis.

First, we wish to thank **GOD Almighty** who created the heavens and earth, who helped us in completing this project and we also thank our parents who encouraged us in this period of research.

We would like to express our sincere gratitude to **The Management** of **Lords Institute of Engineering and Technology, Hyderabad** for providing us with an excellent platform and resources to successfully carry out this project.

We would also like to thank **Dr. Ravi Kishore Singh, Principal, L.I.E.T.** for extending his help in overall completion of this project work.

We would like to express my deep sense of gratitude **to Dr. K. Nagi Reddy, Professor & HOD**, **Information Technology, Lords Institute of Engineering & Technology, Hyderabad,** for his encouragement and cooperation throughout the project.

We would like to thank **Dr. Ayesha Mariyam, Associate Professor, Dept. of Information Technology, Lords Institute of Engineering & Technology**, Hyderabad, our project internal guide, for her guidance and help. Her insight during the course of our research and regular guidance were invaluable to us.

Lastly, we acknowledge the support of our faculty members, friends, and family, who inspired and encouraged us throughout this journey.

Mohammed Sohail Ahmed (160923737008)
Syed Sameer (160923737046)
Shaik Waseem (160923737056)

Vision of the Institute

Lords Institute of Engineering and Technology strives for excellence in professional education through quality, innovation and teamwork and aims to emerge as a premier institute in the state and across the nation.

Mission of the Institute

1. To impart quality professional education that meets the needs of present and emerging technological world.
2. To strive for student achievement and success, preparing them for life, career and leadership.
3. To provide a scholarly and vibrant learning environment that enables faculty, staff and students to achieve personal and professional growth.
4. To contribute to advancement of knowledge, in both fundamental and applied areas of engineering and technology.
5. To forge mutually beneficial relationships with government organizations, industries, society and the alumni.

PRINCIPAL
Principal
Lords Institute of Engineering & Tech.
(An Autonomous Institution)
Sy. No. 32, Himayath Sagar, Hyderabad-500091.T.S.

LORDS INSTITUTE OF ENGINEERING &TECHNOLOGY

Approved by AICTE/Affiliated to Osmania University/Estd.2003.
Accredited 'A' grade by NAAC
(UGC Autonomous Institution)

DEPARTMENT OF INFORMATION TECHNOLOGY

Vision of the Department:

To be a frontier in Information Technology focusing on quality professional education, innovation and employability.

Mission of the Department:

DM1: Adopt innovative teaching learning processes to achieve stated outcomes and sustained performance levels.

DM2: Provide learner centric environment to enrich knowledge, skills and innovation through industry academia collaborations.

DM3: Train the concerned stakeholders on latest technologies to meet the industry needs.

DM4: Inculcate leadership, professional, interpersonal skills and ethical values to address the contemporary societal issues.

Note: DM: Department Mission

Head of the Department

Head of the Department

B.E Information Technology Program Educational Objectives (PEOs):

PEO1	Be a competent software engineer in IT and allied industry providing viable solutions.
PEO2	Exhibit professionalism, engage in lifelong learning and adopt to changing industry and societal needs.
PEO3	Be effective as an individual and also cohesive in a group to execute multidisciplinary projects.
PEO4	Pursue higher studies in Information Technology with emphasis on competency and innovation.

Head of the Department
Head of the Department
Information Technology
Lords Institute of Engineering & Technolo
Himayath Sagar, Hyderabad-91

LORDS INSTITUTE OF ENGINEERING &TECHNOLOGY

Approved by AICTE/Affiliated to Osmania University/Estd.2003.
Accredited 'A' grade by NAAC
(UGC Autonomous Institution)

DEPARTMENT OF INFORMATION TECHNOLOGY

B.E Information Technology Program Outcomes (POs):

Engineering Graduates will be able to:

S. No.	Program Outcomes (POs)
1.	**PO1: Engineering Knowledge:** Apply knowledge of mathematics, natural science, computing, engineering fundamentals and an engineering specialization as specified in WK1 to WK4 respectively to develop to the solution of complex engineering problems.
2.	**PO2: Problem Analysis:** Identify, formulate, review research literature and analyze complex engineering problems reaching substantiated conclusions with consideration for sustainable development. (WK1 to WK4)
3.	**PO3: Design/Development of Solutions:** Design creative solutions for complex engineering problems and design/develop systems/components/processes to meet identified needs with consideration for the public health and safety, whole-life cost, net zero carbon, culture, society and environment as required. (WK5)
4.	**PO4: Conduct Investigations of Complex Problems:** Conduct investigations of complex engineering problems using research-based knowledge including design of experiments, modelling, analysis & interpretation of data to provide valid conclusions. (WK8).
5.	**PO5: Engineering Tool Usage:** Create, select and apply appropriate techniques, resources and modern engineering & IT tools, including prediction and modelling recognizing their limitations to solve complex engineering problems. (WK2 and WK6)
6.	**PO6: The Engineer and The World:** Analyze and evaluate societal and environmental aspects while solving complex engineering problems for its impact on sustainability with reference to economy, health, safety, legal framework, culture and environment. (WK1, WK5, and WK7).
7.	**PO7: Ethics:** Apply ethical principles and commit to professional ethics, human values, diversity and inclusion; adhere to national & international laws. (WK9)
8.	**PO8: Individual and Collaborative Team work:** Function effectively as an individual, and as a member or leader in diverse/multi-disciplinary teams.
9.	**PO9: Communication:** Communicate effectively and inclusively within the engineering community and society at large, such as being able to comprehend and write effective reports and design documentation, make effective presentations considering cultural, language, and learning differences
10.	**PO10: Project Management and Finance:** Apply knowledge and understanding of engineering management principles and economic decision-making and apply these to one's own work, as a member and leader in a team, and to manage projects and in multidisciplinary environments.
11.	**PO11: Life-Long Learning:** Recognize the need for, and have the preparation and ability for i) independent and life-long learning ii) adaptability to new and emerging technologies and iii) critical thinking in the broadest context of technological change. (WK8)

Head of the Department
Head of the Department
Information Technology
Lords Institute of Engineering & Technology
Himayath Sagar, Hyderabad-91

B.E Information Technology Program Specific Outcomes (PSOs):

PSO1	**Professional Skills:** Identify, analyze requirements, design and implement computer programs in the area of artificial intelligence, machine learning, big data analytics and networking of varying complexity.
PSO2	**Problem-Solving Skills:** Deliver quality service to IT industry and provide solutions to real-life problems applying modern computer languages, software methods and tools.

Head of the Department
Head of the Department
Information Technology
Lords Institute of Engineering & Technolo
Himayath Sagar, Hyderabad-91

Course Outcomes: Project Phase- I

After completion of the project, the student will be able to

S.No	Description	Blooms Taxonomy Level
PP.I.CO1	Demonstrate the ability to synthesize and apply the knowledge and skills acquired in the academic program to the real-world problems.	BTL3
PP.I.CO2	Evaluate different solutions based on economic and technical feasibility	BTL4
PP.I.CO3	Effectively plan a project and confidently perform all aspects of project management.	BTL5
PP.I.CO4	Demonstrate effective written and oral communication skills	BTL4
PP.I.CO5	Prepare the documentation report and perform the presentation of the project work	BTL3

LORDS INSTITUTE OF ENGINEERING &TECHNOLOGY
Approved by AICTE/Affiliated to Osmania University/Estd.2003.
Accredited 'A' grade by NAAC
(UGC Autonomous Institution)

DEPARTMENT OF INFORMATION TECHNOLOGY

Course Articulation Matrix:

Mapping of Course Outcomes (COs) with Program Outcomes (POs) and Program Specific Outcomes (PSOs):

Course Outcomes (COs)	Program Outcomes (POs)											Program Specific Outcomes (PSOs)	
	PO1	PO2	PO3	PO4	PO 5	PO 6	PO7	PO 8	PO 9	PO 10	PO 11	PSO 1	PSO2
PP.I.CO1	3	2	2	-	2	2	-	-	3	-	-	2	2
PP.I.CO2	3	3	2	3	2	-	2	-	3	-	-	-	2
PP.I.CO3	3	3	3	-	3	3	1	2	2	3	2	3	-
PP.I.CO4	3	2	2	3	3	3	3	2	-	-	2	3	3
PP.I.CO5	3	3	3	3	3	3	3	2	3	3	-	3	3
AVG	**3**	**2.6**	**2.5**	**3**	**2.6**	**2.7**	**2.2**	**2**	**2.9**	**3**	**2**	**2.7**	**2.5**

Level:

1- Low correlation (Low), 2- Medium correlation (Medium), 3-High correlation (High)

SDG Mapping:

SDG	Mapped Indicator	SDG	Mapped Indicator	SDG	Mapped Indicator
1 NO POVERTY		7 AFFORDABLE AND CLEAN ENERGY		13 CLIMATE ACTION	
2 ZERO HUNGER		8 DECENT WORK AND ECONOMIC GROWTH	✓	14 LIFE BELOW WATER	
3 GOOD HEALTH AND WELL-BEING		9 INDUSTRY, INNOVATION AND INFRASTRUCTURE		15 LIFE ON LAND	
4 QUALITY EDUCATION		10 REDUCED INEQUALITIES		16 PEACE, JUSTICE AND STRONG INSTITUTIONS	✓
5 GENDER EQUALITY		11 SUSTAINABLE CITIES AND COMMUNITIES		17 PARTNERSHIPS FOR THE GOALS	
6 CLEAN WATER AND SANITATION		12 RESPONSIBLE CONSUMPTION AND PRODUCTION	✓		

ABSTRACT

The Enterprise AI Trust, Risk & Governance Management Platform is an enterprise-grade application designed to help organizations identify, assess, monitor, and manage risks associated with AI and Generative AI systems throughout their lifecycle.The platform maintains an inventory of AI applications, models, datasets, vendors, and use cases and evaluates them against configurable governance policies. It can assess risks such as hallucination, bias, privacy violations, sensitive-data exposure, prompt injection, insecure outputs, excessive AI autonomy, model drift, reliability issues, and regulatory/compliance gaps. The design can be aligned with the NIST AI Risk Management Framework, whose core functions are Govern, Map, Measure, and Manage, and with current OWASP GenAI security guidance. The system provides risk scoring, AI model assessments, control tracking, policy management, audit trails, incident management, human approval workflows, and executive dashboards. Organizations can register an AI system, perform an initial risk assessment, execute automated evaluation tests, identify gaps, assign remediation actions, and continuously monitor the system after deployment.For a final-year implementation, the platform can use simulated enterprise AI systems and datasets rather than requiring access to real corporate AI infrastructure.

Keywords : AI Governance, AI Risk Management, Trustworthy AI, Generative AI, Risk Scoring, AI System Registry, NIST AI RMF, OWASP LLM, Audit Trail.

TABLE OF CONTENTS

Certificate i

Declaration ii

Acknowledgement iii

Vision and Mission of the Institute iv

Vision and Mission of the Department v

Program Educational Objectives vi

Program Outcomes vii

Program Specific Outcomes viii

Course Outcomes ix

Course Articulation Matrix x

Abstract xi

Contents xii

List of Figures xiv

List of Tables xv

CHAPTER-1: INTRODUCTION 1

1.1 Introduction

1.2 Objectives

1.3 Organization of thesis

CHAPTER-2: LITERATURE SURVEY 4

CHAPTER-3: EXISITING SYSTEM 9

3.1 Introduction

3.2 Drawbacks of Existing System

CHAPTER-4: PROPOSED SYSTEM 12

4.1 Introduction

4.2 System Architecture

CHAPTER-5: METHODOLOGIES **18**

5.1 Technologies Used

CHAPTER-6: DESIGN AND IMPLEMENTATION **23**

6.1 Requirements

CHAPTER-7: CONCLUSION AND FUTURE SCOPE **30**

8.1 Conclusion

8.2 Future Scope and Enhancements

REFERENCES **32**

List of Figures

SI.no	Fig.no	Name of the Figure	Page No.
1	4.1	Conceptual System Architecture	15
2	4.2	AI Governance Lifecycle Workflow	17

List of Tables

SI.no	Table	Name of the Table	Page No.
1	2.1	Literature Survey	6
2	4.1	Mapping of the Four Governance Questions to the Platform	13
3	6.1	Software Requirements	25
4	6.2	Hardware Requirements	26

CHAPTER 1
INTRODUCTION

1.1 Introduction

Artificial intelligence is increasingly embedded in business workflows, decision-support systems, customer-facing applications, and software-development tools. Generative AI adds capabilities such as natural-language response generation and document summarization, but it also introduces risks including hallucination, prompt injection, sensitive-data disclosure, unsafe output handling, excessive autonomy, and inconsistent responses. Traditional software inventories and security checklists may not capture the lifecycle-specific risks associated with AI systems.

Organizations therefore need a structured approach to identify which AI systems exist, what purpose each system serves, which data and models it uses, who owns it, what risks it presents, which controls apply, and whether the system has been assessed and approved. Governance also needs to continue after deployment because model performance, data distributions, threats, and business context can change.

AI systems are often adopted across separate teams and vendors, making it difficult to maintain a complete inventory and a consistent record of risk assessments, evaluation results, approvals, incidents, and remediation. Without a unified governance workflow, organizations may have incomplete ownership records, undocumented data usage, inconsistent risk scoring, insufficient evidence for audits, and delayed responses to AI-related incidents.

This project proposes a centralized platform that supports registration, risk assessment, AI evaluation, policy and compliance tracking, human approval, audit evidence, incident handling, and continuous monitoring. The aim is to design an enterprise-oriented platform that helps organizations register AI systems, assess their risks, evaluate trustworthiness and generative-AI security, manage controls and approvals, and maintain traceable governance records throughout the AI lifecycle. It is intended as a governance-support tool rather than an autonomous substitute for legal, security, or domain-expert judgment.

The scope of the project is a final-year academic implementation using simulated enterprise AI systems and synthetic test records where real corporate infrastructure is unavailable. The intended scope includes the governance application, a rule-based risk engine, a Python-based evaluation service, persistent records, role-based access, human review, and a dashboard. The scope does not assume direct access to proprietary enterprise models, production datasets, or regulatory certification. Any optional integrations, such as vector search, external LLM APIs, Prometheus, Grafana, or Kubernetes, are treated as extensions unless they are implemented and demonstrated.

In summary, a centralized governance platform can improve traceability by linking each AI system to its owner, use case, risks, evaluation runs, controls, incidents, and approval history. A consistent workflow can help teams identify missing documentation and prioritize remediation. Explicit human approval and audit records also make it easier to understand why a system was approved, rejected, or conditionally approved.

1.2 Objectives

- To maintain a centralized inventory of AI applications, models, datasets, vendors, owners, and business use cases.
- To capture system purpose, deployment environment, user groups, data sensitivity, and business impact.
- To calculate transparent, configurable risk scores from impact, likelihood, and exposure.
- To plan and record evaluation tests for accuracy, reliability, hallucination, bias, toxicity, latency, prompt injection, and sensitive-data leakage.
- To track policies, controls, compliance mappings, evidence, approval decisions, incidents, and remediation actions.
- To provide dashboard views of inventory, risk distribution, overdue actions, incidents, and governance status.
- To support reassessment and monitoring rather than treating governance as a one-time activity.

1.3 Organization of Thesis

The following is the format of the thesis, which is outlined in eight chapters. A brief description of each chapter is as follows:

The first chapter consists of the Introduction, Objectives, and Organization of Thesis, introducing the problem and the objectives of the project. The second chapter contains the Literature Survey, which surveys relevant frameworks and technical approaches. The third chapter covers System Analysis and Requirements, where the system requirements and feasibility are specified. The fourth chapter presents the System Study and Design, including the architecture, workflow, risk model, and conceptual data design. The fifth chapter describes the Input and Output Design. The sixth chapter identifies the proposed Software Environment. The seventh chapter presents the System Testing and Results Discussion, including the test plan and reporting approach. Finally, the eighth chapter gives the Conclusion, which summarizes the Phase-I design and future work, followed by the references.

CHAPTER 2

LITERATURE SURVEY

Batool et al. [1] carried out a systematic review of AI governance covering 28 research papers published between 2013 and 2023. The papers were identified through Google Scholar and Scopus (2,918 results at first) following the Kitchenham guidelines, and only those that passed quality checks were kept. The authors studied governance through four questions: who is governing, what is being governed, when governance is applied, and how it is done. They also sorted governance into five levels: team, organization, industry, national and international. Only 3 of the 28 studies answered all four questions, most governance solutions work at the organization level while none work at the team or national level, and studies mostly focused on one or two ethical principles, with fairness the most common followed by privacy. However, the paper reports that ethical principles get too little attention, humans are not involved enough, and current governance approaches are not enough. It also notes that the studies did not cover standards such as ISO and NIST well.

Papagiannidis, Mikalef and Conboy [2] reviewed research on how organizations govern AI responsibly and proposed a research framework. Their work shows that responsible AI is not only about technology and that it also needs clear responsibilities, working processes and cooperation between people in the organization. This supports linking each AI system with its risk assessments, control assignments, approval workflows and remediation tracking instead of keeping them in separate places.

Bach et al. [3] studied how responsible AI ideas are used in real organizations, looking at practices such as documentation, risk management, accountability and evaluation of AI systems. Their review shows that principles like "be fair" and "be transparent" are not enough alone, and that organizations need practical records such as assessments, evidence and review decisions.

NIST [4] introduced the Artificial Intelligence Risk Management Framework (AI RMF 1.0) in 2023, built around four functions: Govern, which sets up policies, roles and oversight; Map, which understands the context and possible impact of the AI system; Measure, which assesses and tracks risks; and Manage, which prioritizes and treats the

risks. The proposed platform follows this structure. However, its scoring formula (Impact × Likelihood × Exposure) is its own method and is not defined by NIST, and using NIST as a reference does not mean the platform is certified or compliant.

NIST [5] later extended the framework for generative AI through the Generative AI Profile (NIST AI 600-1, 2024). It covers risks such as made-up (hallucinated) content, privacy leaks, information integrity and security problems, and it guides the GenAI evaluation tests for hallucination, sensitive-data exposure and unsafe outputs.

In addition, several guidelines and standards support the design of the platform. The OWASP Top 10 for LLM Applications [6] lists the main security risks for LLM-based applications, including prompt injection, sensitive information disclosure and excessive agency, and forms the basis of the GenAI security assessment. ISO/IEC 42001:2023 [7] is a standard for building an AI management system inside an organization and supports the policy, control and audit features. The EU AI Act [8] is a law that sorts AI systems by risk level and sets stricter rules for high-risk ones, which supports risk-based classification in the platform.

Table 2.1 Literature Survey

S.NO	Title of paper	Methodology	Results	Advantages	Drawbacks
1	AI Governance: A Systematic Literature Review (2025) [1]	Systematic review of 28 papers (2013–2023) found through Google Scholar and Scopus (2,918 initial results), following the Kitchenham guidelines with quality checks; governance studied through four questions (who, what, when, how) and five levels (team, organization, industry, national, international).	Only 3 of 28 studies answered all four questions; 7 solutions work at the organization level and none at team or national level; studies mostly focus on one or two ethical principles, fairness most common, then privacy.	Base paper of the project; its four questions guide the platform design (registry for who and what, lifecycle workflow for when, policies, controls, approvals and evaluation tests for how).	Ethical principles get too little attention, humans are not involved enough, and current governance approaches are not enough; ISO and NIST standards are not covered well.
2	Responsible Artificial Intelligence Governance: A Review and Research Framework (2025) [2]	Review of research on how organizations govern AI responsibly, proposing a research framework.	Shows responsible AI is not only about technology; it also needs clear responsibilities, working processes and cooperation between people.	Supports linking each AI system with risk assessments, control assignments, approval workflows and remediation tracking in one place.	–
3	Insights into Suggested Responsible AI	Systematic review of how responsible AI ideas are used in real	Principles like “be fair” and “be transparent” are	Matches the records the platform stores	–

	Practices in Real-World Settings: A Systematic Literature Review (2025) [3]	organizations (documentation, risk management, accountability, evaluation of AI systems).	not enough alone; practical records such as assessments, evidence and review decisions are needed.	(assessments, evidence, review decisions).	
4	Artificial Intelligence Risk Management Framework (AI RMF 1.0) (2023) [4]	Framework built around four functions: Govern, Map, Measure and Manage.	Govern sets policies, roles and oversight; Map understands context and impact; Measure assesses and tracks risks; Manage prioritizes and treats risks.	Platform follows this structure: inventory and use-case records support Map, risk scoring and evaluation tests support Measure, policies and approvals support Govern, remediation and monitoring support Manage.	The project's scoring formula (Impact × Likelihood × Exposure) is its own method, not defined by NIST; using NIST as a reference does not mean certification or compliance.
5	Generative AI Profile (NIST AI 600-1, 2024) [5]	Extension of the NIST framework for generative AI.	Covers risks such as hallucinated content, privacy leaks, information integrity and security problems.	Guides the GenAI evaluation tests for hallucination, sensitive-data exposure and unsafe outputs; each result records test conditions, result	–

				and limitations.	
6	OWASP Top 10 for LLM Applications [6]	List of the main security risks for LLM-based applications.	Includes prompt injection, sensitive information disclosure and excessive agency.	Basis of the GenAI security assessment.	–
7	ISO/IEC 42001:2023 [7]	Standard for building an AI management system inside an organization.	–	Supports the policy, control and audit features.	–
8	EU AI Act [8]	Law that sorts AI systems by risk level.	Sets stricter rules for high-risk AI systems.	Supports risk-based classification in the platform.	–

CHAPTER 3
EXISTING SYSTEM

3.1 Introduction

AI governance is more than registering a model. An organization also needs to know who owns each AI system, what business purpose it serves, which data and models it uses, what checks were done and what the results were, whether problems were fixed, and who approved the system. A review of current practice and the relevant literature reveals the following approaches:

At present, many organizations track AI systems in spreadsheets, wikis or general IT asset lists. These are supported by general IT security checklists, a one-time review before launch, and separate tools for testing, incidents and policy. When these records are kept in separate places, problems appear. A system may have good test results but no approval, while another may be approved but still have an unresolved security finding.

Batool, Zowghi and Bano [1] carried out a systematic review of 28 research papers on AI governance published between 2013 and 2023. They studied governance through four questions: who is governing, what is being governed, when governance is applied, and how it is done, and sorted it into five levels: team, organization, industry, national and international. Only 3 of the 28 studies answered all four questions, most solutions (7) work at the organization level, and none work at the team or national level. However, the paper reports that ethical principles get too little attention, humans are not involved enough, and current governance approaches are not enough. It also notes that standards such as ISO and NIST were not covered well.

Papagiannidis, Mikalef and Conboy [2] reviewed how organizations govern AI responsibly and proposed a research framework. Their work shows that responsible AI is not only about technology, and that it also needs clear responsibilities, working processes and cooperation between people in the organization.

Bach et al. [3] studied how responsible AI ideas are used in real organizations, looking

at documentation, risk management, accountability and evaluation of AI systems. They show that principles such as "be fair" and "be transparent" are not enough alone, and that organizations need practical records such as assessments, evidence and review decisions.

NIST [4] proposed the AI Risk Management Framework (AI RMF 1.0), built around four functions: Govern, Map, Measure and Manage. It helps organizations set up policies, roles and oversight, understand the context and impact of an AI system, assess and track risks, and prioritize and treat them. However, it does not prescribe the risk-scoring formula used in this project, and using it as a reference does not mean a platform is certified or compliant. NIST [5] also extended the framework for generative AI through the Generative AI Profile (NIST AI 600-1, 2024), which covers hallucinated content, privacy leaks, information integrity and security problems.

Furthermore, several guidelines and standards support AI governance. The OWASP Top 10 for LLM Applications [6] lists the main security risks of LLM-based applications, such as prompt injection, sensitive information disclosure and excessive agency. ISO/IEC 42001:2023 [7] is a standard for building an AI management system inside an organization, and the EU AI Act [8] sorts AI systems by risk level and sets stricter rules for high-risk ones.

3.2 Drawbacks of Existing System

There are several issues with the existing systems. Here are a few of them which will be addressed in the proposed system:

- Outdated Spreadsheet Inventory: A spreadsheet inventory easily becomes outdated and has no link to risks or approvals.
- Missing AI-Specific Risk Coverage: General IT security checklists do not cover AI risks such as hallucination or prompt injection.
- No Reassessment After Deployment: A one-time review before launch does not reassess the system after deployment, even though models and data change.
- No Single View of a System: Separate tools for testing, incidents and policy give no single view of one AI system's full history.

- Principles Without Enforcement: Many frameworks stay at the level of principles and give organizations no ready-to-use tool, and ethical guidelines are often only suggestions with nothing to enforce them.
- Weak Oversight and Audit Evidence: Human oversight and audit records are often weak, which leaves insufficient evidence for audits.
- Standards Not Turned into Working Systems: Standards like NIST and ISO are well known but are not often turned into a working system.
- Incomplete and Inconsistent Records: Without a unified workflow, organizations may have incomplete ownership records, undocumented data usage, inconsistent risk scoring and delayed responses to AI-related incidents.

CHAPTER 4

PROPOSED SYSTEM

4.1 Introduction

- The proposed system aims to overcome the drawbacks of the existing practice by joining AI inventory and use-case management, risk scoring, trustworthiness and GenAI security assessment, data governance, policy and control management, compliance mapping, human approval, incident management, monitoring and audit evidence, and executive reporting in one platform.

- The design follows one simple idea: AI governance is not a single step. An AI system must be registered, assessed, tested, approved, monitored and reviewed again from time to time. Every part of the design supports one of these steps and keeps a record of it. The parts depend on each other: a risk assessment must point to a registered system, a test result must say what was tested, and a remediation action must point to a finding. Approval and audit records then preserve how decisions were made, while monitoring and reassessment continue the process after launch.

- The design uses the four governance questions of the base paper [1] (who, what, when and how) to decide what the platform should contain. Each question was turned into a set of features: user roles and system ownership for "who", the AI System Registry and Data Governance module for "what", the lifecycle stage stored for every system and the monitoring after deployment for "when", and the policies, controls, risk scoring and evaluation tests for "how". It can also follow the four NIST AI RMF functions (Govern, Map, Measure, Manage) and OWASP GenAI security guidance. Following them as a reference does not mean the platform is compliant or that the AI systems it tracks are trustworthy.

- The platform makes the records of AI chatbots and other AI services easy to access for the owners of companies and enterprises, so that they can track them and make changes whenever they need. This feature is known as human approval: the platform waits for human approval before changes are made,

which makes it different from other platforms.

- The platform is implemented using React for the web interface, Java Spring Boot for the governance services, Python with FastAPI for the evaluation service and PostgreSQL for storage.

4.2 Problem Statement

AI systems are often adopted across separate teams and vendors, making it difficult to maintain a complete inventory and a consistent record of risk assessments, evaluation results, approvals, incidents, and remediation. Without a unified governance workflow, organizations may have incomplete ownership records, undocumented data usage, inconsistent risk scoring, insufficient evidence for audits, and delayed responses to AI-related incidents. Therefore, there is a need for a centralized platform that supports registration, risk assessment, AI evaluation, policy and compliance tracking, human approval, audit evidence, incident handling, and continuous monitoring. It is intended as a governance-support tool rather than an autonomous substitute for legal, security, or domain-expert judgment.

Table 4.1 Mapping of the four governance questions to the platform

Question from the base paper	**Meaning**	**How the platform answers it**
Who is governing?	The people responsible for oversight	User roles, ownership of each AI system, reviewer and approver roles
What is governed?	Data and AI systems	AI System Registry, Dataset records, Data Governance module
When is it governed?	Pre-development, during development, post-development	Lifecycle stage stored for every system; assessments before approval; monitoring after deployment
How is it governed?	Policies, guidelines, frameworks, tools	Policy and Control Management, Compliance Mapping, risk scoring, evaluation tests

4.3 System Architecture

4.3.1 Working Structure of the Enterprise AI Trust, Risk & Governance Management Platform

The platform uses a layered architecture. Each layer has one job, so that a change in one layer does not break the others. The presentation layer is a web interface built with React, where users log in, register AI systems, fill risk questionnaires, view test results, approve or reject systems and see dashboards. All requests from the web interface first reach the API Gateway, which checks who the user is, passes the request to the correct service and keeps request handling in one place. Permissions are checked in the backend for every request, and hiding a button in the interface is not treated as enough protection.

Three core governance services built with Java Spring Boot work behind the gateway. The AI Registry Service stores AI systems, models, datasets, vendors and use cases. The Risk Assessment Service collects risk answers and calculates the risk score. The Policy and Compliance Service stores policies, controls and their mapping to frameworks such as NIST AI RMF and OWASP GenAI guidance.

The AI Evaluation Service, built with Python FastAPI, runs the tests on AI systems. It has three groups of tests: LLM tests (hallucination, toxicity, prompt injection, sensitive-data disclosure), ML tests (accuracy, precision, recall, F1, robustness, reliability) and security tests (prompt attacks, insecure output, excessive agency, API abuse). The results are sent back to the governance services. All records, including inventory, assessments, evaluation results, policies, incidents, approvals and audit logs, are saved in the PostgreSQL data layer. Finally, the monitoring and audit part records activity and supports continuous monitoring and reporting.

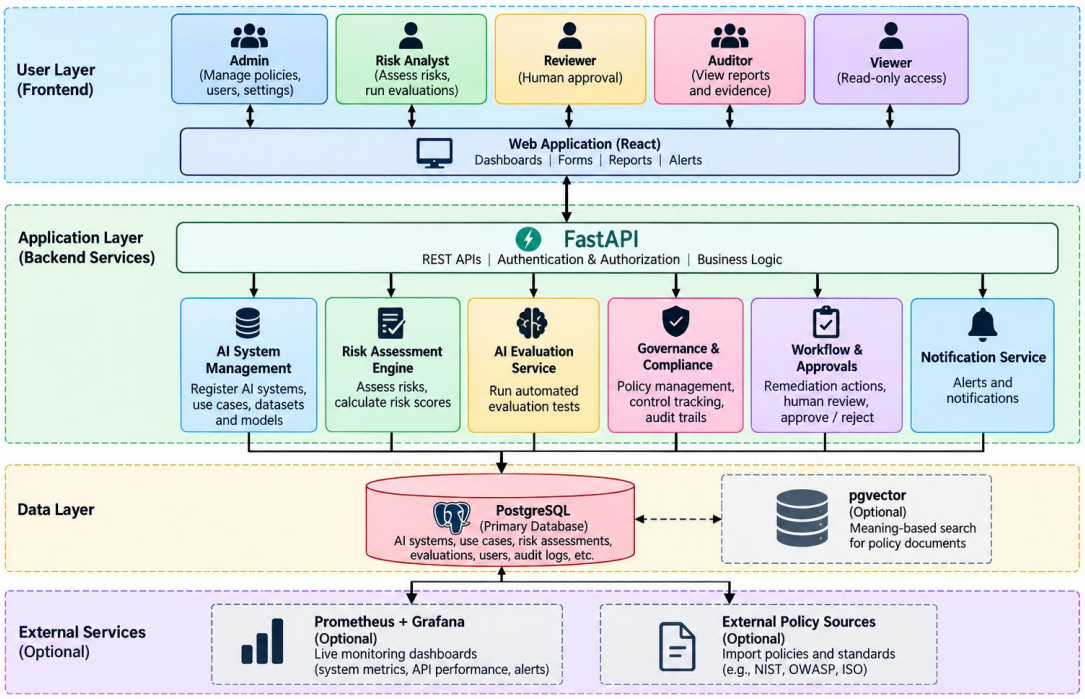


Figure 4.1: Conceptual System Architecture

4.3.2 Working Process

Step – 1: Register AI System and Identify Business Use Case

The owner creates the record of the AI system. The purpose, users and business domain of the system are then written down in the use-case record, so that every later assessment knows what it is assessing.

Step – 2: Classify the System and Identify Data and Model

The system is placed in a type, for example a chatbot, a prediction model or an AI agent. The datasets and the model used by the system are then linked to its record.

Step – 3: Perform Risk Assessment and Calculate Risk Score

The user fills a questionnaire about the system and the risks are listed. The answers are turned into three ratings, Impact, Likelihood and Exposure, each from 1 (lowest) to 5 (highest). The system then applies the formula Risk Score = Impact × Likelihood × Exposure, so the score ranges from 1 to 125. For example, Impact = 5, Likelihood = 4 and Exposure = 4 gives 5 × 4 × 4 = 80 out of 125. The formula is defined by this project and is not prescribed by NIST, and the risk bands (such as Low, Medium and High) are

set by each organization and can be changed in the settings.

Step – 4: Run Evaluation Tests

The configured tests are sent to the AI system through the evaluation service and the results are stored, including the expected answer, the actual answer, the score and whether the test passed. A test that was not run is stored as "Not Run" and is never shown as a pass.

Step – 5: Identify Governance Gaps and Assign Remediation Actions

Missing owners, missing documents, failed controls and missing approvals are listed as governance gaps. Each gap becomes a remediation action with an owner and a due date.

Step – 6: Human Review and Decision

An authorised reviewer studies the risks, test results and evidence, and gives one decision: the system is approved, rejected or conditionally approved. The reason for the decision is saved. A system can be conditionally approved only if at least one remediation action is attached to the decision, and a rejected system must have a written reason. These rules are checked by the backend.

Step – 7: Deploy and Monitor

After deployment, performance, drift, incidents and risk changes are watched. Every important action, such as creating a record, changing a score or approving a system, is stored in the audit log with the user, the time and the change made, and audit records cannot be edited by normal users.

Step – 8: Periodic Reassessment

The assessment is repeated on a schedule or when something changes. The platform stores the lifecycle stage of each system so that checks can be made at every stage. Through this process, each system moves through the statuses Draft, Submitted, Under Assessment, Under Review, Approved, Conditionally Approved, Rejected, Under Monitoring and Reassessment Due.

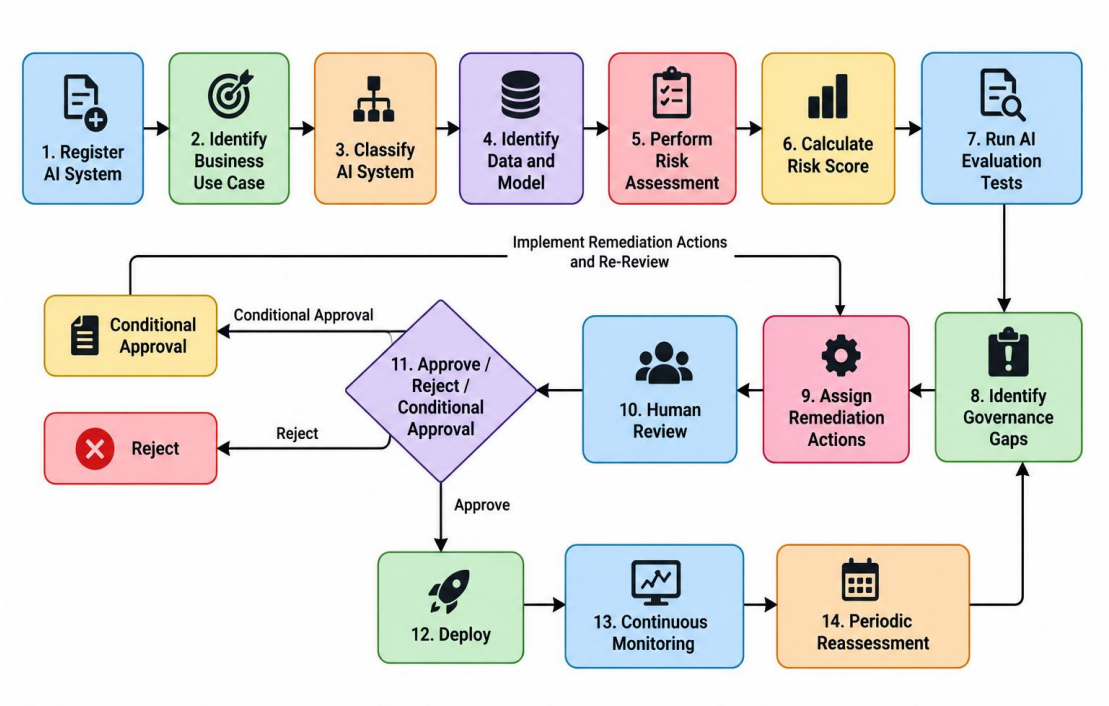


Figure 4.2: AI Governance Lifecycle Workflow

CHAPTER 5
METHODOLOGY

5.1 Methodology Used

Centralized AI System Registry and Use-Case Management

Every governance activity in the platform starts with the registry. A user enters the system name, owner, vendor, model name, type of AI, deployment type, data sensitivity and business impact. The use-case record explains why the system is used and who uses it, and it captures the purpose, business domain, users, data types, deployment environment and AI capabilities. The registry covers AI applications, models, agents, vendors, datasets and use cases. Without this record, an assessment would not know what it is assessing.

Configurable Risk Scoring

The risk assessment module collects the answers to a questionnaire and turns them into three ratings, each from 1 to 5. Impact shows how serious the harm would be if the risk happens, Likelihood shows how probable it is that the risk happens, and Exposure shows how many people, systems or data are open to the risk. The score is calculated as Impact × Likelihood × Exposure, so it ranges from 1 to 125. A score alone does not tell the user what to do, so each organization sets its own bands. As an example, 1–25 can be Low (accept and monitor), 26–60 Medium (plan remediation), 61–100 High (remediate before approval) and 101–125 Critical (escalate and block approval). These bands are only an example and can be changed in the settings. The formula is meant to help in sorting risks by priority and does not replace expert judgement.

The risks themselves are grouped into six categories: model risk (drift, performance drop), generative AI risk (hallucination, prompt injection, toxic output), data risk (PII exposure, poor quality, poisoning), security risk (API abuse, unauthorised access, model theft), governance risk (no owner, no approval, expired review) and compliance risk (failed controls, missing evidence). One system can have several risks at the same time, and each risk is stored separately with its own score and can be linked to a system, a control and a fix. Separating the categories helps reviewers distinguish between

different types of issues, such as data-quality problems, access-control vulnerabilities and missing governance records.

AI Evaluation and GenAI Security Assessment

The Trustworthiness Evaluation module checks accuracy, robustness, reliability, explainability, privacy and security. The GenAI Security Assessment and Model Evaluation modules send test inputs to the AI system through the evaluation service and store the expected answer, the actual answer, the score and whether the test passed. The possible evaluation measures are hallucination, toxicity, bias, prompt injection, sensitive-data leakage, robustness, accuracy, latency, reliability, cost and drift. A measure can be reported only if its detector or test has been built, and each result states the method and the test inputs used. A test that was not run is stored as "Not Run" and is never shown as a pass.

Data Governance

Datasets are recorded with a classification such as public, internal, confidential or restricted. The module also records where the data came from (lineage), checks for personal information (PII) and notes data quality problems. Access controls are supported so that datasets are protected according to their classification.

Human Approval Workflow and Role-Based Access Control

After assessment, an authorised reviewer reads the risks, test results and evidence and gives one decision, and the reason for the decision is saved. This module directly answers the lack of human involvement mentioned in the base paper [1]. The platform has six types of users: the AI System Owner, who provides system and use-case details; the Risk and Evaluation Analyst, who assesses risk and runs tests; the Governance and Compliance Officer, who maintains policies and controls; the Reviewer or Approver, who takes the approval decision; the Administrator, who manages users and settings; and the Executive, who has view-only access to dashboards and summary reports. The exact permissions are decided during implementation. Permissions are enforced by the application itself, not only by hiding buttons in the interface. Hiding a button only changes what the user sees on the screen. It does not stop a user from sending a request directly to the backend, for example through a browser tool or an API client such as

Postman. For this reason, the backend checks the identity and role of the user for every request, before any record is created, changed, approved or deleted. Spring Security with role-based access control (RBAC) applies these checks on each API endpoint. For example, an AI System Owner can edit only the systems they own, and only a Reviewer or Approver can record an approval decision.

Audit and Evidence Management and Database Design

Every important action, such as creating a record, changing a score or approving a system, is stored in the audit log with the user, the time and the change made. Audit records cannot be edited by normal users. All records are stored in a PostgreSQL relational database. The main proposed tables are User, AI_System, AI_Model, AI_UseCase, Dataset, Risk, Risk_Assessment and Risk_Control. One AI system can have many use cases, models, datasets, risks, evaluations and incidents. One risk can have many assessments over time, which allows risk change to be tracked. One incident or risk can lead to many remediation actions, and one system can have many approval records because it is reviewed again at later dates. The base paper treats data and systems as the two things being governed [1], and the model it follows also names humans and processes [16]. In the database, data is held in Dataset, systems in AI_System, humans in User and Approval, and processes in the status and lifecycle fields.

5.2 Technologies Used

- Frontend Framework: React – a JavaScript library for building web pages from small reusable parts called components. A dashboard card, a form field or a table can each be a component that is reused on many pages.
- Type Safety: TypeScript – adds data types to JavaScript, which helps to catch mistakes, such as sending a text where a number is expected, before the program runs.
- Frontend Libraries: React Router – moves between pages without reloading the whole site; Axios – sends requests to the backend API; React Hook Form – handles form input and validation; Material UI or Bootstrap – gives ready-made buttons, tables and layouts; Recharts or Apache ECharts – draws charts such as risk distribution graphs.

- Backend Framework: Java 21 and Spring Boot 3.x – Java 21 is a long-term-support version widely used for enterprise software, and Spring Boot helps to build REST web services quickly with less set-up code. The backend and the interface talk by REST: the interface sends a request, such as GET /api/systems, and the backend returns data in JSON format.
- Spring Modules: Spring Web – creates REST API endpoints, for example to register a system or fetch a risk; Spring Data JPA – saves and reads records in PostgreSQL without writing all SQL by hand; Spring Security – handles login and role checks; Spring Validation – checks input rules such as required fields and ranges; Spring Actuator – gives health and status endpoints for operations.
- Evaluation Service: Python with FastAPI – a fast framework for creating APIs, used because most AI and data libraries are available for Python.
- AI and Data Libraries: scikit-learn – calculates accuracy, precision, recall and F1; Pandas and NumPy – load, clean and calculate on test data; Hugging Face Transformers – gives access to models that can be used for checking toxicity or similar text properties; LLM APIs – send prompts to the AI system under test and bring back its answers; LangChain and LlamaIndex – optional helpers for building LLM workflows.
- Database: PostgreSQL – an open-source relational database management system used to store and manage the structured data of the platform, with reliable storage, transaction management, data consistency and support for complex relationships between records. It integrates with Spring Boot through Spring Data JPA. The pgvector extension or Qdrant may optionally be used as a vector database to store text embeddings, so that a search such as "documents about customer data leakage" can retrieve relevant policies, previous assessments and audit records.
- Security: Spring Security, JWT, OAuth2, RBAC, API Gateway, HashiCorp Vault and HTTPS/TLS – used for login, permissions, secret storage and encrypted traffic.
- Deployment and Automation: Docker – puts each service in a container so it runs the same on every computer; Kubernetes – manages many containers; Helm – packages Kubernetes settings; GitHub Actions or Jenkins – runs the build and tests when code changes.

- Monitoring and Logs: Prometheus, Grafana, and ELK or OpenSearch – used for metrics, dashboards and log search.
- Testing Tools: JUnit 5, Mockito and Spring Boot Test – used for unit testing the Java code; Postman and REST Assured – used to test the APIs; OWASP ZAP – used for web security scanning; JWT and RBAC tests and a prompt-injection test suite – check login, permissions and generative AI safety.

CHAPTER 6
DESIGN AND IMPLEMENTATION

6.1 Requirements

6.1.1 Overall Description

The system is an enterprise AI governance application. It has a web interface built with React, a governance backend built with Java Spring Boot, an AI evaluation service built with Python FastAPI, and a PostgreSQL database. Users log in to register AI systems, fill risk questionnaires, view test results, approve or reject systems and see dashboards. The requirements come from the project specification and are guided by the base paper [1] and the NIST AI RMF [4]. The project is a final-year academic implementation that uses simulated enterprise AI systems and synthetic test records, because real corporate AI infrastructure is not available. It does not assume direct access to proprietary enterprise models, production datasets, or regulatory certification.

Functional requirements:

- AI System Registry (FR-01): Register AI applications, models, agents, vendors, datasets and use cases.
- Use-Case Management (FR-02): Record purpose, business domain, users, data types, deployment environment and AI capabilities.
- Risk Assessment (FR-03): Identify and calculate risks using configurable questionnaires and rules.
- Trustworthiness Evaluation (FR-04): Evaluate accuracy, robustness, reliability, explainability, privacy and security.
- GenAI Security Assessment (FR-05): Support tests for prompt injection, sensitive-data disclosure, insecure outputs and excessive agency, where implemented.
- Model Evaluation (FR-06): Record metrics such as accuracy, precision, recall,

F1, hallucination rate, toxicity, latency and response consistency.

- Data Governance (FR-07): Support dataset registration, classification, lineage, PII detection, quality checks and access controls.

- Policy and Control Management (FR-08): Manage AI policies, controls, approval requirements and compliance rules.

Non-functional requirements:

- Security (NFR-01): The system should provide role-based access control, input validation, and protection of sensitive data, verified through access-control and security tests.

- Traceability (NFR-02): Every assessment, test, decision, and evidence item should be linked to its respective AI system, verified by reviewing stored records.

- Reliability (NFR-03): The system should store and retrieve records consistently, verified through API and database testing.

- Usability (NFR-04): The system should provide clear forms and dashboards for non-technical users, evaluated through feedback during demonstrations.

- Maintainability (NFR-05): The architecture should be modular, so that the evaluation service can be changed without affecting the governance backend, verified through code structure reviews.

- Honest Reporting (NFR-06): The system should never display unexecuted tests as passed, validated through test cases TC-07 to TC-09.

Feasibility study:

- Technical: The project uses widely available tools: React for the interface, Spring Boot for the backend, Python with FastAPI for the evaluation service and PostgreSQL for storage. These are well documented and suit a team of three students.

- Economic: The core stack consists of open-source technologies, so licence cost is expected to be low. Optional items (external LLM APIs, Kubernetes, Vault, Grafana) may add cost and are treated as extensions.

- Operational: The workflow follows steps that organizations already do: register, assess, review, approve and monitor. The platform is a governance-support tool and does not replace legal, security or domain experts.

- Scope: The project uses simulated AI systems and synthetic data, so results from synthetic data do not prove performance on real systems.

6.1.2 Software Requirements

Table 6.1 Software Requirements

Software Component	**Version/Specification**
Frontend Framework	React (JavaScript library for building the web interface)
Type Safety	TypeScript
Frontend Libraries	React Router, Axios, React Hook Form, Material UI or Bootstrap, Recharts or Apache ECharts
Backend Language	Java 21 (long-term-support version)
Backend Framework	Spring Boot 3.x (Spring Web, Spring Data JPA, Spring Security, Spring Validation, Spring Actuator)
Evaluation Service	Python with FastAPI
AI and Data Libraries	scikit-learn, Pandas, NumPy, Hugging Face Transformers, LLM APIs (LangChain and LlamaIndex optional)
Database	PostgreSQL (optional: pgvector extension or Qdrant)
Security	Spring Security, JWT, OAuth2, RBAC, API Gateway, HashiCorp Vault, HTTPS/TLS
Deployment and Automation	Docker, Kubernetes, Helm; GitHub Actions or Jenkins
Monitoring and Logs	Prometheus, Grafana, ELK or OpenSearch

Testing Tools	JUnit 5, Mockito, Spring Boot Test, Postman, REST Assured, OWASP ZAP

6.1.3 Hardware Requirements

Table 6.2: Hardware Requirements

Hardware Component	Minimum Requirement
Processor	Dual-core, 2.0 GHz (quad-core or better recommended)
RAM	8 GB (16 GB recommended)
Hard Disk	20 GB free space (50 GB free SSD recommended)
Network	Basic internet connection (stable broadband recommended for LLM API calls)
Display	1366 x 768 (1920 x 1080 recommended)

The figures above are normal development settings and not measured needs of this project. Running Docker with four containers is easier with 16 GB RAM.

6.2 Input Design

Input design explains what information the user gives to the platform and how it is collected. Good input design reduces mistakes: if a user enters a wrong rating, the risk score will be wrong. The design follows a few simple rules: ask only for information that is needed, group related fields together on one form, use drop-down lists wherever possible so that spellings do not change, mark required fields clearly, and link every record to the AI system it belongs to. The main input forms are as follows:

- AI System Registration Form: This form creates the record of an AI application, model or agent. The owner fills in the system name, business domain, AI type, model name, vendor, deployment type, data sensitivity, business impact, owner and status. After saving, the system gets a unique system ID.
- Use-Case Form: This form explains why the AI system exists. It asks for the purpose, business domain, user group, types of data used, deployment environment and the AI capabilities such as text generation, prediction or

decision support.

- Risk Assessment Form: The analyst chooses the risk category (model, generative AI, data, security, governance or compliance), writes a short description and gives three ratings from 1 to 5: Impact, Likelihood and Exposure. The score is calculated by the system and is not typed in by the user.
- Evaluation Test Form: This form records or uploads test cases. Each test has a test ID, the linked system ID, the prompt, the expected response, the test category, and later the actual response, score, pass status and execution time. Tests can be entered one by one or uploaded as a CSV file.
- Dataset Form: This form registers a dataset with its name, source, classification (public, internal, confidential or restricted), whether it contains personal information and its quality status.
- Policy and Control Form: The governance officer enters a policy title and description, the controls under it, whether approval is required and the framework reference, for example a NIST AI RMF function or an OWASP LLM risk.
- Incident Form: This form records an AI failure or security event. It asks for the incident ID, the system affected, incident type, severity, description, date detected, status and resolution.
- Remediation Action Form: Each action has a short description, the linked risk or incident, the person responsible, a due date and a status (Open, In Progress, Done, Overdue).
- Approval Form: The reviewer sees a summary of the assessment, chooses Approve, Reject or Conditional Approval, and writes a reason. For a conditional approval, the reviewer also selects the actions that must be finished first.

Input validation checks every value before it is saved. The checks happen in the web interface (for quick feedback) and again on the server (for safety). The ratings for Impact, Likelihood and Exposure must be whole numbers from 1 to 5, the system name is required, the owner must be an existing user, the email must have a valid format, and the due date cannot be earlier than today. The system ID used in tests, risks and incidents must match an existing AI system, and severity and status must be chosen from a fixed list. Validation also separates three test states: Passed, Failed and Not Run, and a test that was not run is never counted as passed. The risk thresholds are set by

each organization, so the form does not assume universal risk bands and instead reads the bands from the settings page.

6.3 Output Design

Output design explains what the platform shows back, such as dashboards, risk reports and test results. Outputs are designed so that every number can be traced to a record, because if a dashboard shows a number without its source, the reviewer cannot trust it. The main outputs are as follows:

- Executive Dashboard: The dashboard is the first page after login. It shows the total number of registered AI systems, the number of high-risk systems, open incidents, open remediation actions, the spread of risk levels (for example a bar or pie chart) and the compliance status. A list of systems that need attention is shown at the bottom, and the numbers are calculated from the stored records.
- Risk Assessment View: This page shows the risk category, the three ratings, the calculated score, the configured category (for example High) and the status of the fix. It also shows the history of earlier scores, so the reviewer can see if the risk is rising or falling.
- Evaluation Results View: This page lists each test with its category, expected and actual response, score, pass status and execution time. A summary at the top shows how many tests passed, failed or were not run.
- Incident View: Incidents are shown in a table with type, severity, description, date, status and resolution. The user can filter by severity or by system.
- Audit and Evidence View: This page shows the assessment history, the evidence files linked to each assessment, approval decisions and the audit trail with the name of the user and the time of each action.
- Notification View: This page lists alerts such as a critical risk, a failed control or an overdue action. Alerts can also be sent by email when the organisation has set this up.
- Downloadable Reports: A user with the right permission can export an assessment report or an audit report as PDF or CSV. The report includes the system details, risk scores, test results, actions and the approval decision.

The platform follows three rules for output integrity. First, every output is linked to its source record, so the user can click through to the original data. Second, a metric is shown only when the matching test has been run. If a test has not been run, the page shows "Not evaluated" instead of a number. Third, sample data is clearly labelled: if the demonstration uses synthetic AI systems, the dashboard shows the label "Sample data", and if the database is empty, the dashboard shows zero rather than made-up values. Metrics such as accuracy, hallucination rate, attack success rate, PII leakage rate and average latency are reported only with the test inputs and the way they were calculated.

CHAPTER 7
CONCLUSION AND FUTURE SCOPE

7.1 Conclusion

AI is now used in many business tasks, and with it come risks such as hallucination, prompt injection, data leakage, unfair results and loss of performance over time. The base paper, which reviewed 28 studies, showed that organisations need clear answers on who governs AI, what is governed, when governance happens and how it is done [1]. It also showed that few existing solutions answer all four questions together.

This project proposed the Enterprise AI Trust, Risk & Governance Management Platform to bring these answers into one place. The platform keeps a registry of AI systems, use cases, models and datasets. It records risk assessments, evaluation results, controls, compliance mappings, incidents, remediation actions, human approvals and audit evidence. All of these are connected through one lifecycle: register, assess, test, review, approve, monitor and reassess.

The design uses a React and TypeScript interface, a Java 21 and Spring Boot backend, a Python and FastAPI evaluation service and a PostgreSQL database. Keeping these parts separate makes the system easier to develop, test and extend. The risk formula, Impact × Likelihood × Exposure with each factor from 1 to 5, gives a simple and open way to prioritise risks. It is a project-defined aid and does not replace the judgement of experts.

The requirements, design, input and output specification, software environment and test plan form a base for implementation and verification. The quality of the final system must be judged from real test evidence, such as observed results, defects and measured response times. The platform does not guarantee AI safety, fairness, security or legal compliance. Its value is that it helps responsible people organise evidence and make decisions in a more consistent and traceable way.

Program Outcome Achieved: PO1, PO2, PO3, PO4, PO5, PO7, PO8, PO9, PO11.

7.2 Future Scope and Enhancements

The following items are possible future work. They should be treated as planned work until they are built and verified.

1. **Automatic discovery of AI systems.** Connect to model registries, cloud platforms, MLOps pipelines and service catalogues to reduce manual entry.
2. **Continuous evaluation and monitoring.** Add connectors that collect performance, drift, availability and safety signals, where data access and security allow.
3. **More generative AI security tests.** Add tests for prompt injection, sensitive-data exposure, insecure tool use and unsafe output, with reproducible evidence.
4. **Configurable and explainable risk scoring.** Let organisations define their own categories, weights, thresholds and escalation rules, and show which factors drove a score.
5. **Wider framework mapping.** Keep versioned mappings to NIST AI RMF, ISO/IEC 42001 and 23894, OWASP guidance and laws such as the EU AI Act, reviewed by qualified governance and legal staff.
6. **Advanced analytics.** Show trends of open risks, overdue actions, repeated findings and approval delays, filtered by business unit, owner, model type and lifecycle stage.
7. **Notifications and deadlines.** Add reminders and escalation for reviews, due dates, pending approvals and incident follow-up.
8. **Evidence integrity.** Add file versioning, retention rules, access logs and integrity checks for audit material.
9. **Enterprise identity.** Support single sign-on, multi-factor authentication and directory integration.
10. **Scalability and reliability.** Add container orchestration, automated build pipelines, health checks, backup and recovery.

REFERENCES

[1] A. Batool, D. Zowghi, and M. Bano, "AI governance: a systematic literature review," AI and Ethics, vol. 5, pp. 3265–3279, 2025. https://doi.org/10.1007/s43681-024-00653-w

[2] E. Papagiannidis, P. Mikalef, and K. Conboy, "Responsible artificial intelligence governance: A review and research framework," The Journal of Strategic Information Systems, vol. 34, no. 2, 2025.

[3] T. A. Bach et al., "Insights into suggested Responsible AI (RAI) practices in real-world settings: a systematic literature review," AI and Ethics, 2025.

[4] National Institute of Standards and Technology (NIST), Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, Gaithersburg, MD, USA, Jan. 2023. https://doi.org/10.6028/NIST.AI.100-1

[5] National Institute of Standards and Technology (NIST), Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1, Gaithersburg, MD, USA, July 2024. https://doi.org/10.6028/NIST.AI.600-1

[6] ISO/IEC, ISO/IEC 42001:2023, Information Technology – Artificial Intelligence – Management System. Geneva, Switzerland: ISO, 2023. https://www.iso.org/standard/81230.html

[7] ISO/IEC, ISO/IEC 23894:2023, Information Technology – Artificial Intelligence – Guidance on Risk Management. Geneva, Switzerland: ISO, 2023. https://www.iso.org/standard/77304.html

[8] OWASP Foundation, OWASP Top 10 for Large Language Model Applications, 2025 edition. https://genai.owasp.org/llm-top-10/

[9] European Parliament and Council of the European Union, "Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)," Official Journal of the European Union, 2024. https://eur-lex.europa.eu/eli/reg/2024/1689/oj

[10] Q. Lu, L. Zhu, X. Xu, J. Whittle, D. Zowghi, and A. Jacquet, "Responsible AI pattern catalogue: a collection of best practices for AI governance and engineering," ACM Computing Surveys, vol. 56, 2024. https://doi.org/10.1145/3626234

[11] OECD, "Recommendation of the Council on Artificial Intelligence," OECD/LEGAL/0449, adopted 2019, amended 2024. https://legalinstruments.oecd.org/en/instruments/OECD-LEGAL-0449

[12] M. Mitchell et al., "Model cards for model reporting," in Proceedings of the Conference on Fairness, Accountability, and Transparency (FAT '19), Atlanta, GA, USA, 2019, pp. 220–229. https://doi.org/10.1145/3287560.3287596

[13] T. Gebru et al., "Datasheets for datasets," Communications of the ACM, vol. 64, no. 12, pp. 86–92, 2021. https://doi.org/10.1145/3458723

[14] European Parliament and Council of the European Union, "Regulation (EU) 2016/679 (General Data Protection Regulation)," Official Journal of the European Union, 2016. https://eur-lex.europa.eu/eli/reg/2016/679/oj

[15] V. Vakkuri, K.-K. Kemell, M. Jantunen, E. Halme, and P. Abrahamsson, "ECCOLA – a method for implementing ethically aligned AI systems," Journal of Systems and Software, vol. 182, art. 111067, 2021.

[16] D. Zowghi and F. da Rimini, "Diversity and inclusion in artificial intelligence," in Responsible AI: Best Practices for Creating Trustworthy AI Systems, Q. Lu et al., Eds. Sydney, Australia: Addison-Wesley, 2023.